

15/04/2026

Azure Cloud

מעבדה 2

SPF, DKIM ו-DMARC — אימות דוא"ל ב-Microsoft 365

פישיוג ואבטחת מייל — בדיקת מנגנוני אימות דוא"ל בסביבת הענן של Microsoft

מטרות המעבדה

- הבנת מנגנוני אימות דוא"ל: SPF, DKIM ו-DMARC
- בדיקת הגדרות SPF/DKIM/DMARC דרך Microsoft 365 Admin Center
- שימוש ב-Exchange Online Message Trace לניתוח תוצאות אימות
- בחינת Authentication Headers במיילים ב-Outlook on the Web
- זיהוי תקלות אימות נפוצות ופתרון בסביבה עננית
- הגדרת מדיניות DMARC הדרגתית (none → quarantine → reject)

דרישות מקדימות

- גישה ל-Microsoft 365 Admin Center עם הרשאות Global Admin או Exchange Admin
- גישה ל-Microsoft 365 Defender Portal — security.microsoft.com
- גישה ל-Exchange Admin Center — admin.exchange.microsoft.com
- חשבון Exchange Online פעיל עם תיבת דואר
- הבנה בסיסית של רשומות DNS (TXT, CNAME, MX)
- דפדפן מודרני (Edge / Chrome)

רקע תיאורטי — שלושת עמודי אימות הדוא"ל

SPF — Sender Policy Framework

SPF היא רשומת DNS מסוג TXT שמגדירה אילו שרתי מייל מורשים לשלוח הודעות בשם הדומיין. כאשר שרת מייל מקבל הודעה, הוא בודק את כתובת ה-IP של השרת השולח מול רשומת ה-SPF של הדומיין ב-MAIL FROM (Envelope Sender).

מנגנונים עיקריים:

- `:include` — כלול רשומת SPF של דומיין אחר (למשל: `(include:spf.protection.outlook.com`
- `:ip4: / ip6` — כתובת IP ספציפית או טווח CIDR
- `:a` — כתובת ה-A record של דומיין
- `:mx` — שרתי ה-MX של הדומיין

:Qualifiers

- `all (Hard Fail)-` — דחה מיילים מ-IPs שלא ברשימה
- `all (Soft Fail)~` — סמן כחשוד אבל אל תדחה
- `all (Neutral)?` — אין המלצה

DKIM — DomainKeys Identified Mail

DKIM מוסיף חתימה דיגיטלית (RSA/Ed25519) לכתרת המייל. השרת השולח חותם עם מפתח פרטי, והמפתח הציבורי מפורסם ב-DNS כרשומת TXT תחת `selector._domainkey.domain.com`. שרת הנמען מאמת שהחתימה תקינה ושתוכן המייל לא שונה במעבר.

שדות חתימה עיקריים:

- `=d` — הדומיין החותם
- `=s` — ה-Selector (שם המפתח)
- `=h` — רשימת ה-Headers שנכללים בחתימה
- `Hash =bh=` — של גוף ההודעה
- `=b` — החתימה עצמה

DMARC — Domain-based Message Authentication, Reporting & Conformance

DMARC מאחד את SPF ו-DKIM עם מדיניות ודיווח. הוא דורש **Alignment** — שהדומיין בשדה `From`: (שהמשתמש רואה) יתאים לדומיין שאומת ב-SPF או DKIM.

מדיניות (Policy):

- `p=none` — ניטור בלבד, ללא פעולה
- `p=quarantine` — העבר לספאם
- `p=reject` — דחה את המייל

פרמטרים נוספים:

- `=rua` — כתובת לקבלת דוחות מצטברים (Aggregate)
- `=ruf` — כתובת לקבלת דוחות פורנזיים (Forensic)
- `=pct` — אחוז המיילים שהמדיניות חלה עליהם
- `=adkim` — מצב Alignment ל-DKIM (s=strict / r=relaxed)
- `=aspf` — מצב Alignment ל-SPF (s=strict / r=relaxed)

חלק א — בדיקת הגדרות SPF ב-Microsoft 365 Admin Center

שלב 1

היכנסו ל-Microsoft 365 Admin Center:

`https://admin.microsoft.com`

בתפריט הצדדי, נווטו אל:

`Settings → Domains`

בחרו את הדומיין הארגוני הראשי שלכם מהרשימה.

אם יש מספר דומיינים, בדקו כל אחד בנפרד — כולם צריכים רשומות SPF.

שלב 2

לחצו על לשונית **DNS Records** ואתרו את רשומת ה-SPF.

הרשומה המומלצת של Microsoft 365:

```
Type: TXT
Host: @
Value: v=spf1 include:spf.protection.outlook.com -all
```

ודאו שהרשומה קיימת ושהיא כוללת את `include:spf.protection.outlook.com`

חשוב: חייבת להיות רק רשומת SPF אחת לכל דומיין. מספר רשומות SPF גורמות ל-Permerror!

שלב 3

אם הארגון משתמש בשירותי צד שלישי לשליחת מיילים (Marketing, CRM, Helpdesk), ודאו שהם כוללים:

```
v=spf1 include:spf.protection.outlook.com include:sendgrid.net include:sendgrid.net
```

שירותים נפוצים וה-include שלהם:

SendGrid: `include:sendgrid.net`

Mailchimp: `include:servers.mcsv.net`

Salesforce: `include:_spf.salesforce.com`

Google Workspace: `include:_spf.google.com`

HubSpot: `include:spf.hubspot.com`

מגבלה קריטית: SPF מאפשר מקסימום 10 DNS lookups (כולל lookups מקוננים). חריגה גורמת ל-Permerror וכשל מוחלט של SPF!

שלב 4

בדקו את כמות ה-DNS lookups ברשומה שלכם:
היכנסו לכלי החינמי:

```
https://www.kitterman.com/spf/validate.html
```

הכניסו את שם הדומיין ובדקו:

האם הרשומה תקינה סינטקטית?

כמה DNS lookups נדרשים?

האם יש שגיאות?

אם מספר ה-lookups חורג מ-10, שקלו SPF Flattening — החלפת IP addresses ב-includes ישירים.

שלב 5

בצעו בדיקת SPF מתקדמת דרך **Exchange Online PowerShell** (אופציונלי):

```
# Exchange Online-התחברות ל
Connect-ExchangeOnline -UserPrincipalName admin@yourdomain.com

# הצגת כל הדומיינים המאושרים בארגון
Get-AcceptedDomain | Format-Table DomainName, DomainType, Default

# לכל דומיין SPF בדיקת רשומת
$domains = Get-AcceptedDomain
foreach ($d in $domains) {
    Write-Host "--- $($d.DomainName) ---" -ForegroundColor Cyan
    Resolve-DnsName $d.DomainName -Type TXT |
        Where-Object {$_.Strings -like "*spf*"} |
        Select-Object -ExpandProperty Strings
}
```

PowerShell מאפשר סריקה אוטומטית של כל הדומיינים בארגון בפקודה אחת.

חלק ב — הגדרת ובדיקת DKIM ב-Microsoft 365 Defender

שלב 1

היכנסו ל-**Microsoft 365 Defender Portal** ונווטו להגדרות DKIM:

```
https://security.microsoft.com
→ Email & Collaboration
→ Policies & Rules
```

- Threat Policies
- Email Authentication Settings
- DKIM

תראו רשימה של כל הדומיינים בארגון עם סטטוס DKIM.

שלב 2

בחרו את הדומיין הראשי. אם DKIM לא מופעל (Disabled), לחצו **Enable**.

Microsoft 365 דורש שני CNAME records ב-DNS שלכם:

Record 1:

Host: selector1._domainkey

Type: CNAME

Value: selector1-yourdomain-com._domainkey.yourdomain.onmicrosoft.com

Record 2:

Host: selector2._domainkey

Type: CNAME

Value: selector2-yourdomain-com._domainkey.yourdomain.onmicrosoft.com

חובה להוסיף את שני ה-CNAME records אצל ספק ה-DNS שלכם לפני לחיצה על Enable! אחרת תקבלו שגיאה.

שלב 3

לאחר הוספת ה-CNAME records (המתינו עד 48 שעות ל-DNS propagation), חזרו וודאו:

- הסטטוס השתנה ל-**Enabled** (סימון ירוק)
- מוצג **Last checked** עם תאריך עדכני
- ה-Selector הפעיל מוצג (selector1 או selector2)

כעת כל מייל שנשלח מ-Exchange Online יחתם אוטומטית עם DKIM.

שלב 4

שלחו מייל ניסיון מ-Outlook ובדקו שה-DKIM Signature מופיעה.

פתחו את המייל אצל הנמען → הצגת כותרות → חפשו:

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;  
d=yourdomain.com; s=selector1;  
h=From:Date:Subject:Message-ID:Content-Type:MIME-Version;  
bh=2jUSOH9NhtVGCQWNr9BrIAPreKQj06Sn7XIkfJV0zv8=;  
b=AuUoFEfDxTDkHLLXSZEpZj79LICEps6eda7W3deTVF0k ...
```

שימו לב לפרמטרים:

— הדומיין שחתם `d=yourdomain.com`

— ה-Selector בשימוש `s=selector1`

— אלגוריתם החתימה `a=rsa-sha256`

— מצב Canonicalization (Header/Body) `c=relaxed/relaxed`

שלב 5

בדקו את תוצאת ה-DKIM ב-**Authentication-Results**:

```
Authentication-Results: mx.google.com;  
dkim=pass header.i=@yourdomain.com header.s=selector1 header.b=AuUoFE;  
spf=pass (google.com: domain of user@yourdomain.com designates 40.107.22  
dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=yourdomain.com
```

תוצאת `dkim=pass` מאשרת שהחתימה הדיגיטלית אומתה בהצלחה.

שלב 6

ביצוע **DKIM Key Rotation** (מומלץ כל 6 חודשים):

Rotate DKIM keys → בחרו דומיין → DKIM → Security Portal

Microsoft יעבור אוטומטית מ-selector1 ל-selector2 (או להפך). תהליך ה-rotation שקוף ולא דורש שינוי DNS.

Rotation של מפתחות DKIM מגן למקרה שמפתח פרטי דלף. Microsoft מנהל rotation אוטומטי אבל מומלץ לוודא.

חלק ג — הגדרת מדיניות DMARC הדרגתית

שלב 1

בדקו אם קיימת רשומת DMARC קיימת:

Admin Center → Settings → Domains → yourdomain.com → DNS Records

חפשו רשומת TXT עבור `_dmarc.yourdomain.com`.
אם לא קיימת — נמשיך ליצירה.

שלב 2

שלב 1 — Monitor Mode (שבועות 1-4):

Type: TXT
Host: `_dmarc`
Value: `v=DMARC1; p=none; rua=mailto:dmarc-agg@yourdomain.com; ruf=mailto:dmarc-agg@yourdomain.com; fo=1`

פירוט הפרמטרים:

- `p=none` — ניטור בלבד, המיילים לא מושפעים
- `=rua` — כתובת לקבלת דוחות Aggregate (יומיים, XML)
- `=ruf` — כתובת לקבלת דוחות Forensic (על כל כשל)
- `fo=1` — שלח דוח forensic על כל כשל (SPF או DKIM)

בתקופת ה-Monitor, נתחו את הדוחות וזהו שירותים לגיטימיים ששולחים מיילים בשם הדומיין.

שלב 3

שלב 2 — Quarantine הדרגתי (שבועות 4-8):


```
v=DMARC1; p=quarantine; sp=none; rua=mailto:dmarc-agg@yourdomain.com; pct=
```

התחילו עם `pct=10` — רק 10% מהמיילים הנכשלים יועברו לספאם.

העלו בהדרגה: `pct=25` → `pct=50` → `pct=75` → `pct=100`.

בכל שלב, בדקו את הדוחות לוודא שמיילים לגיטימיים לא נפגעים!

שלב 4

שלב 3 — Reject מלא (לאחר +8 שבועות):

```
v=DMARC1; p=reject; sp=quarantine; rua=mailto:dmarc-agg@yourdomain.com; ru
```

מדיניות סופית:

`p=reject` — מיילים שנכשלים יידחו (לא מגיעים לנמען כלל)

`sp=quarantine` — תת-דומיינים — העברה לספאם (הגנה על `yourdomain.com.*`)

`adkim=s` — Strict DKIM alignment (From domain חייב להתאים בדיוק ל-DKIM d=)

`aspf=s` — Strict SPF alignment (From domain חייב להתאים בדיוק ל-MAIL FROM)

(domain

ברגע שמגיעים ל- `p=reject` עם `pct=100` — הדומיין מוגן באופן מלא מפני Email Spoofing.

שלב 5

ניתוח דוחות DMARC שמגיעים לתיבת המייל:

הדוחות מגיעים בפורמט XML מכל שרת מייל שמקבל הודעות מהדומיין שלכם. דוגמה:

```
<feedback>
  <report_metadata>
    <org_name>google.com</org_name>
    <email>noreply-dmarc-support@google.com</email>
    <date_range>
      <begin>1713139200</begin>
      <end>1713225600</end>
    </date_range>
```

```

</report_metadata>
<record>
  <row>
    <source_ip>203.0.113.55</source_ip>
    <count>47</count>
    <policy_evaluated>
      <disposition>reject</disposition>
      <dkim>fail</dkim>
      <spf>fail</spf>
    </policy_evaluated>
  </row>
  <identifiers>
    <header_from>yourdomain.com</header_from>
  </identifiers>
  <auth_results>
    <spf><domain>malicious-sender.ru</domain><result>pass</result></spf>
  </auth_results>
</record>
</feedback>

```

דוגמה זו מראה: IP 203.0.113.55 שלח 47 מיילים שנדחו. ה-SPF עבר עבור malicious-sender.ru אבל נכשל ב-DMARC Alignment כי ה-From היה yourdomain.com. זהו ניסיון זיוף!

שלב 6

השתמשו בכלים ויזואליים לניתוח דוחות DMARC:

DMARC Analyzer — dmarcanalyzer.com

Postmark DMARC Monitoring (חינמי) — dmarc.postmarkapp.com

Valimail — valimail.com

כלים אלו מציגים את הדוחות בגרפים: מקורות שליחה, שיעורי הצלחה/כשל, IPs חשודים ועוד.

חלק ד — בדיקת Outlook on the Web-2 Authentication Headers

שלב 1

פתחו מייל נכנס ב-Outlook on the Web:

```
https://outlook.office.com
```

בחרו מייל → לחצו על שלוש הנקודות (...) בפינה הימנית העליונה → **View message** → **View** **details**

חלון חדש ייפתח עם כותרות המייל המלאות (Internet Headers).

שלב 2

אתרו את השדה **Authentication-Results** — דוגמה למייל לגיטימי מ-Google:

```
Authentication-Results: spf=pass (sender IP is 209.85.220.41)
  smtp.mailfrom=google.com; dkim=pass (signature was verified)
  header.d=google.com; dmarc=pass action=none
  header.from=google.com; compauth=pass reason=100
```

פירוש:

IP 209.85.220.41 — **spf=pass** מורשה לשלוח עבור google.com
— **dkim=pass** החתימה הדיגיטלית אומתה בהצלחה
— **dmarc=pass action=none** DMARC עבר, לא נדרשת פעולה
— **compauth=pass reason=100** Composite Authentication של Microsoft — ציון 100 = מהימן לחלוטין

כל שלושת המנגנונים עברו — זהו מייל לגיטימי ומאומת.

שלב 3

בחנו מייל **חשוד** — דוגמה לכשל מלא:

```
Authentication-Results: spf=fail (sender IP is 185.234.72.19)
  smtp.mailfrom=suspicious-relay.net;
  dkim=none (message not signed);
  dmarc=fail action=oreject
```

```
header.from=microsoft.com;  
compauth=fail reason=000
```

נקודות עיקריות:

- header.from=microsoft.com אבל smtp.mailfrom=suspicious-relay.net — זיוף שולח!
- dkim=none — המייל לא נחתם כלל (microsoft.com תמיד חותם)
- compauth=fail reason=000 — כשל מוחלט ב-Composite Authentication
- action=oreject — Microsoft ביצע Override Reject

שלב 4

בדקו שדות Microsoft ייחודיים נוספים:

```
X-MS-Exchange-Organization-AuthAs: Anonymous  
X-MS-Exchange-Organization-AuthSource: BN8NAM12FT050.eop-nam12.prod.protec  
X-MS-Exchange-Organization-SCL: 9  
X-Microsoft-Antispam: BCL:8;  
X-Forefront-Antispam-Report: SFV:SPM;SFS:(13230040 ... );DIR:INB;SFP::
```

פירוש הערכים:

- AuthAs: Anonymous — מייל חיצוני (לעומת Internal או Partner)
- SCL: 9 — Spam Confidence Level (0-9, כאשר 9 = ספאם ודאי)
- BCL: 8 — Bulk Complaint Level (0-9)
- SFV:SPM — Spam Filter Verdict: Spam

שלב 5

השתמשו ב-**Message Header Analyzer** של Microsoft לניתוח ויזואלי:

```
https://mha.azurewebsites.net/
```

העתיקו את כל הכותרות מה-View message details והדביקו בכלי.

הכלי מציג:

- Summary:** שולח, נמען, נושא, תאריך

- Received Headers: כל ה-hops עם זמנים ועיכובים
- Authentication: תוצאות SPF/DKIM/DMARC בטבלה קריאה
- Anti-spam: SCL, BCL, PCL ושאר ציוני הספאם
- Other Headers: כל שאר הכותרות המיוחדות

הכלי מפרק את הכותרות המורכבות לטבלה ויזואלית ומזהה בעיות אוטומטית.

חלק ה — Exchange Online Message Trace מתקדם

שלב 1

היכנסו ל-Exchange Admin Center והפעילו Message Trace:

```
https://admin.exchange.microsoft.com  
→ Mail flow → Message trace → + Start a trace
```

שלב 2

הגדירו סינון לזיהוי מיילים שנכשלו באימות:

Senders: השאירו ריק (כל השולחים) או הכניסו דומיין ספציפי

Recipients: תיבת מייל ספציפית לבדיקה

Time range: 7 ימים אחרונים

Report type: Enhanced summary report

Failed | Delivery status: FilteredAsSpam

לחצו Search.

שלב 3

בתוצאות, לחצו על הודעה עם סטטוס FilteredAsSpam ופתחו את Message events:

```
Event: RECEIVE  
Source: SMTP  
Timestamp: 2026-04-15 09:23:17
```

Message-ID: <abc123@suspicious-sender.net>

Client-IP: 185.234.72.19

Event: AGENTINFO

S:SPF=Fail;smtp.mailfrom=suspicious-sender.net

S:DKIM=None

S:DMARC=Fail;action=oreject;header.from=yourdomain.com;p=reject

S:CompAuth=Fail;reason=000;eid=1

Event: DELIVER

Folder: Junk Email

DeliveryPriority: Normal

ניתן לראות בדיוק באיזה שלב המייל סומן כספאם — ה-event AGENTINFO מפרט את תוצאות כל בדיקת אימות.

שלב 4

יצאו דוח מפורט ל-CSV:

Message trace → Enhanced summary report → Submit
→ Downloadable reports (ייצור תוך 2-10 דקות)

פתחו את ה-CSV ב-Excel וסננו:

- עמודת Auth Detail — מכילה תוצאות SPF/DKIM/DMARC
- עמודת Sender Address — כתובת השולח
- עמודת Sender IP — כתובת IP
- עמודת Subject — נושא ההודעה
- עמודת Status — תוצאת ההעברה

שלב 5

צרו חוק (Transport Rule (Mail Flow Rule שמסמן מיילים עם כשלונות אימות:

Exchange Admin Center → Mail flow → Rules → + Add a rule

Condition: A message header includes ...

Header: Authentication-Results

Value: dmarc=fail

Action: Prepend the subject with "[DMARC FAIL]"

Add an X-Header: X-DMARC-Status = Failed

חוק זה מוסיף תיוג ויזואלי למיילים שנכשלו ב-DMARC, כך שמשתמשים יזהו אותם מיד.

חלק ו — פתרון בעיות אימות נפוצות

בעיה	תסמינים	סיבה	פתרון
SPF Permerror	SPF נכשל תמיד ללא קשר ל-IP	יותר מ-10 DNS lookups ברשומה	SPF Flattening — החלפת includes ב-ip4: ישירים, או שימוש בשירות כמו dmarcian
SPF Fail לשירות לגיטימי	מיילים משירות צד שלישי מגיעים לספאם	ה-include של השירות חסר ב-SPF	הוסיפו את ה-include המתאים ברשומת SPF
DKIM Fail	חתימה לא תואמת	Forwarding שינה את התוכן, או CNAME חסר	ודאו CNAME ב-DNS; שקלו הפעלת ARC
DMARC Alignment Fail	SPF pass + DKIM pass אבל DMARC fail	From header domain לא תואם ל-SPF/DKIM domain	ודאו ש-From domain ש-SPF envelope =DKIM d domain
מיילים לגיטימיים נחסמים	משתמשים מדווחים על מיילים שלא מגיעים	DMARC p=reject חוסם שליחה ממקור לא מוגדר	בדקו DMARC reports, הוסיפו את המקור ל-SPF/DKIM
דוחות DMARC לא מגיעים	לא מתקבלים XML reports	כתובת rua/ruf שגויה, או תיבה מלאה	ודאו כתובת rua; אם הדומיין של rua שונה — הוסיפו External Reporting Authorization

בעיה	תסמינים	סיבה	פתרון
Forwarding שובר SPF	מיילים שעוברים forwarding נכשלים ב-SPF	ה-IP של שרת ה-forwarding לא ברשומת SPF המקורית	הפעלת SRS (Sender Rewriting Scheme) או ARC (Authenticated Received Chain)

תוצאה צפויה

לאחר השלמת המעבדה תוכלו:

- לבדוק ולהגדיר רשומות SPF, DKIM ו-DMARC ב-Microsoft 365
- לנתח Authentication Headers ולזהות זיוף שולח
- להשתמש ב-Message Trace לזיהוי ופתרון כשלונות אימות
- ליישם מדיניות DMARC הדרגתית (none → quarantine → reject)
- לנתח דוחות DMARC בפורמט XML ולזהות ניסיונות spoofing
- לפתור בעיות אימות נפוצות בסביבת Exchange Online

שאלות לניתוח

1. מדוע חשוב להתחיל עם `p=none` ולהתקדם בהדרגה ל- `p=reject` ? מה הסיכון במעבר ישיר?

2. מהו ההבדל בין `all (hard fail)` לבין `all (soft fail)` ברשומת SPF? מה ההשלכה על אבטחה?

3. כיצד Email Forwarding שובר אימות SPF? מהם הפתרונות (SRS, ARC)?

4. ארגון גילה ב-DMARC Report ש-IP ברוסיה שולח 500 מיילים ביום בשם הדומיין — מה הצעדים הבאים?

5. מהו `compauth` של Microsoft ובמה הוא שונה מ-DMARC סטנדרטי?

6. מהו ARC (Authenticated Received Chain) ואילו בעיות הוא פותר?

7. כיצד תבדקו אם SPF Flattening נדרש עבור הדומיין שלכם?

סיכום

במעבדה זו למדנו כיצד לנהל את שלושת מנגנוני אימות הדוא"ל בסביבת Microsoft 365. SPF מגדיר אילו שרתים מורשים לשלוח, DKIM מוסיף חתימה דיגיטלית שמאמתת שלמות ההודעה, ו-DMARC מגדיר מדיניות לטיפול בכשלונות ומספק דוחות ניטור. בדיקת Authentication Headers ב-Outlook ושימוש ב-Message Trace מאפשרים ניטור בזמן אמת. יישום נכון של שלושת המנגנונים מספק הגנה רב-שכבתית מפני Email Spoofing — אחד מווקטורי ההתקפה הנפוצים ביותר בפשינג.